

Data and Network Security

(Master Degree in Computer Science and Cybersecurity)

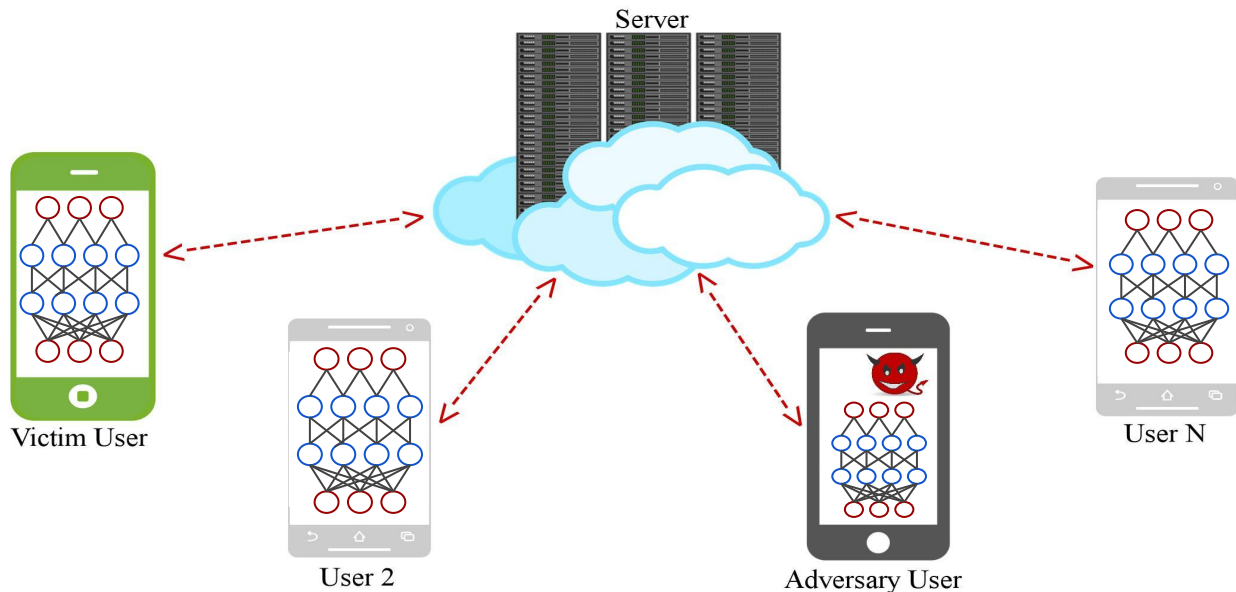
Lecture 6



Outline for today

- **Recap last lecture**
- **APTs**

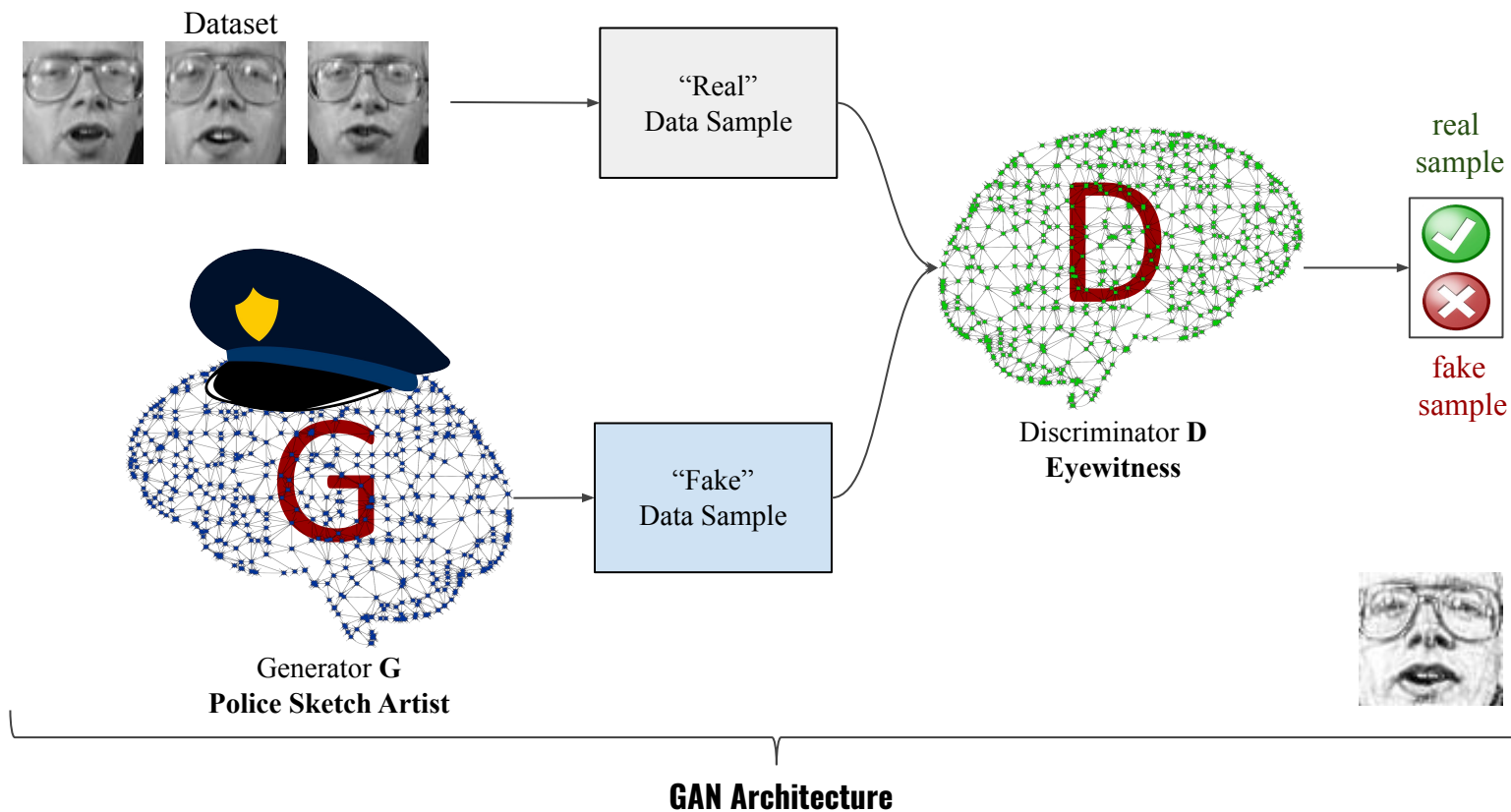
Collaborative Learning Scheme



Adversary's goal?

Reconstruct private samples from the dataset of the victim indirectly influencing the learning of other participants

Generative Adversarial Network



Outline for today

— — —

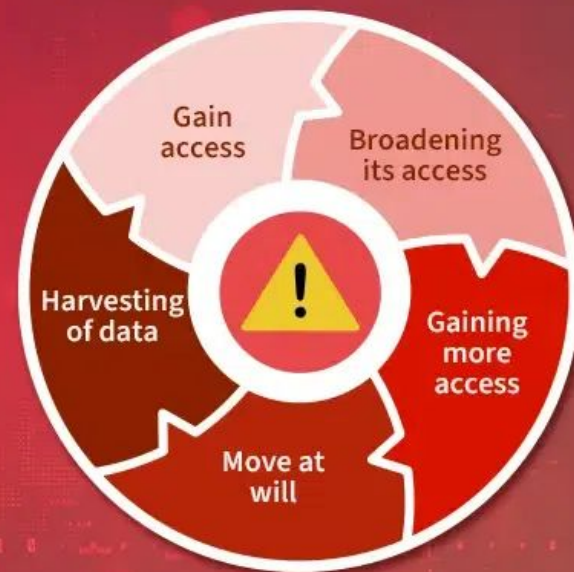
- Recap last lecture
- **APTs**

Not this...



This...

ADVANCED PERSISTENT THREAT

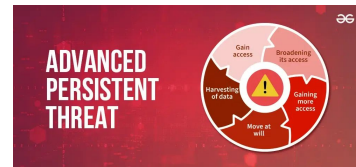


Advanced Persistent Threats



Sophisticated, targeted cyberattack in which an unauthorized entity gains access to a network and remains undetected for an extended period of time.

Advanced Persistent Threats



Sophisticated, targeted cyberattack in which an unauthorized entity gains access to a network and remains undetected for an extended period of time.

- APT attacks are characterized by:**
 - advanced tactics,**
 - stealthy infiltration methods,**
 - persistent presence within the targeted network.**

APTs vs. Common attacks

— — —

Opportunistic (common) attacks:

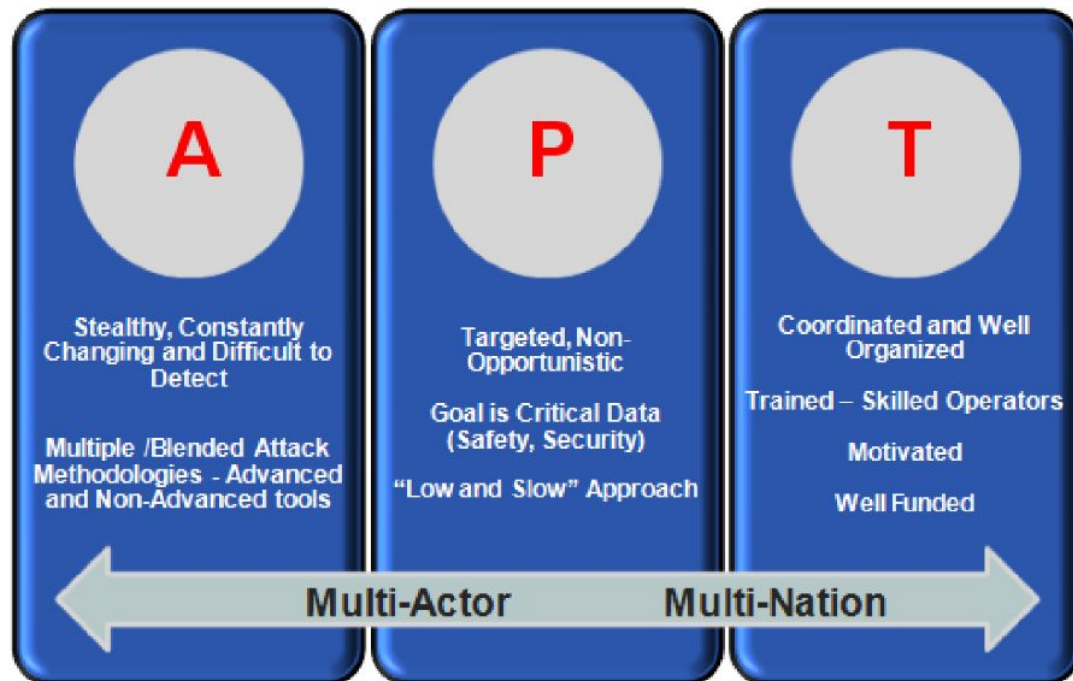
- short-lived
- indiscriminate

APTs vs. Common attacks

APT attacks:

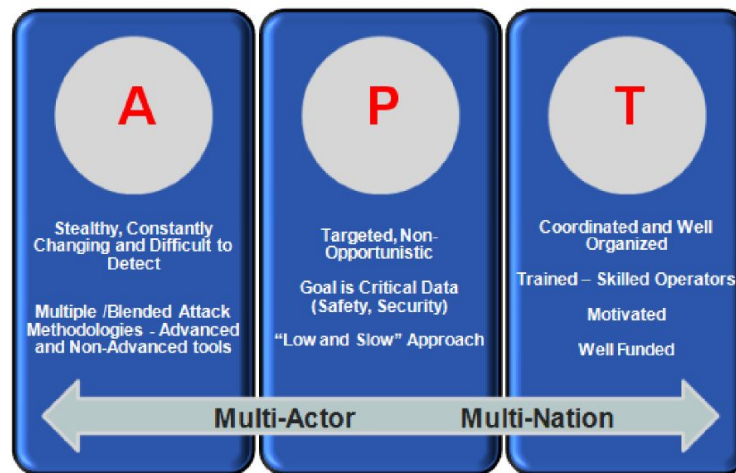
- Carefully planned,
- Well-funded,
- Tailored to target high-value assets, such as sensitive data, intellectual property, or strategic information.

APT



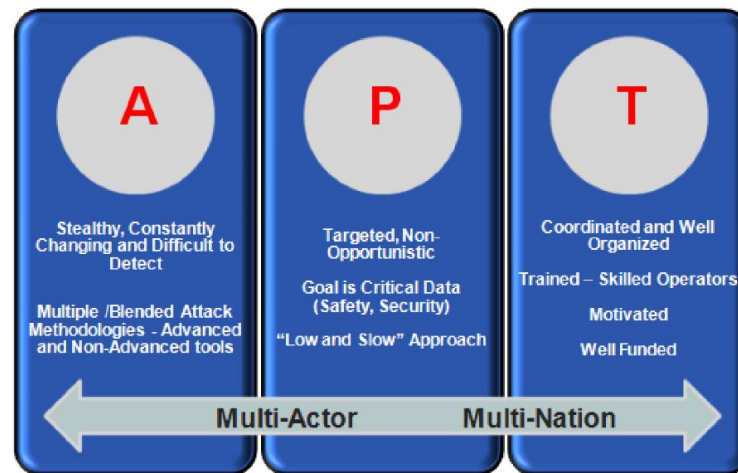
ADVANCED

The attack team has significant levels of expertise and significant resources, allowing the use of multiple and elaborated different attack vectors.



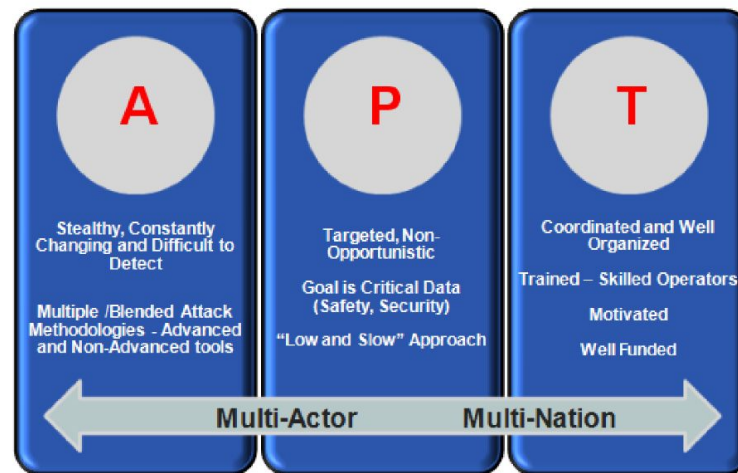
PERSISTENT

The attack team operates in order to remain present and undetected within the organization as long as possible

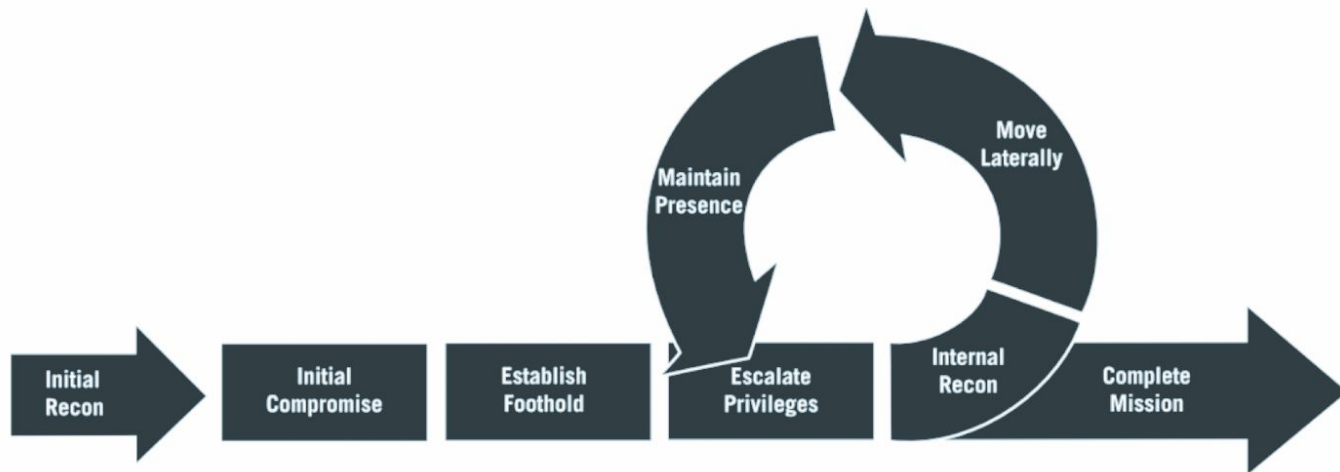


THREAT

Potential to adversely impact organizational operations, their assets, or individuals.



APT - Life Cycle



Why APTs?

- Economic espionage
- Political espionage
- Ideological motivations



Why APTs?



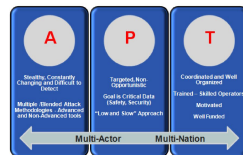
- Economic espionage

Seek to steal valuable intellectual property, trade secrets, or proprietary information from targeted organizations.



Why APTs?

— — —

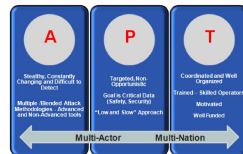


- Political espionage

Nation-state actors may target government agencies, diplomatic organizations, political parties, or foreign entities to gain insights into:

- geopolitical developments,
- national security strategies,
- diplomatic matters (e.g negotiations).
- ...

Why APTs?



- Ideological motivations

Groups or individuals with specific ideological agendas may target organizations or entities that they perceive as adversaries or opponents to advance their ideological goals or raise awareness about social or political issues.

Detecting APTs



To counteract this threat, an entity/organization needs to put some active defense mechanisms in place.

Detecting APTs



To counteract this threat, an entity/organization needs to put some active defense mechanisms in place.

- **Cyber Threat Hunting**

- Process that is put in place in order to tackle (hunt) this kind of sophisticated threat.



Cyber Threat Hunting



Cyber Threat Hunting

Process that is put in place in order to tackle (hunt) this kind of sophisticated threat.

- User/Entity behaviour analytics
- Other intelligence resources

Cyber Threat Hunting



Cyber Threat Hunting

Process that is put in place in order to tackle (hunt) this kind of sophisticated threat.

- User/Entity behaviour analytics
- Other intelligence resources

*non-conventional sophisticated techniques need to be employed due to the fact that this is no common threat, it spans in time and keeps evolving.



Know-How



Understanding such complex attacks requires a lot of knowledge in order to design and develop strategies and defense mechanisms.

What we need is a knowledge framework that will assist us in developing a set of semantic indicators:

- Define and understand the context of the attack.
- Initiate the appropriate countermeasure.

Semantic indicators



Semantic indicators are clues or signals within a set of data that provide insights into the **meaning**, **context**, or **intent** behind the information. These indicators help users interpret and understand the content more accurately.

Threat intelligence analysis to identify:

- **patterns,**
- **trends,**
- **anomalies**

that may indicate malicious activity or suspicious behavior.

MITRE ATT&CK (

Adversarial Tactics, Techniques, and Common Knowledge)



Curated knowledge base and framework that categorizes the tactics, techniques, and procedures used by adversaries during cyber attacks.

Developed by MITRE Corporation, a nonprofit organization that operates federally funded research and development centers, ATT&CK provides a comprehensive taxonomy of cyber threats based on real-world observations and expert analysis.

MITRE ATT&CK



Curated knowledge base and framework that categorizes the tactics, techniques, and procedures used by adversaries during cyber attacks.

Developed by MITRE Corporation, a nonprofit organization that operates federally funded research and development centers, ATT&CK provides a comprehensive taxonomy of cyber threats based on real-world observations and expert analysis.

Started in 2013 with the purpose of documenting common tactics, techniques and procedures against Windows enterprise networks and nowadays it spans almost all main enterprise solutions and also provides mitigations strategies.

MITRE ATT&CK



ATT&CK Matrix for Enterprise

layout: side • show sub-techniques hide sub-techniques

Reconnaissance 10 techniques	Resource Development 8 techniques	Initial Access 10 techniques	Execution 14 techniques	Persistence 20 techniques	Privilege Escalation 14 techniques	Defense Evasion 44 techniques	Credential Access 17 techniques	Discovery 32 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques	Impact 14 techniques
Active Scanning (1)	Acquire Access (1)	Content Injection (1)	Cloud Administration Command (1)	Account Manipulation (1)	Abuse Elevation Control Mechanism (1)	Abuse Elevation Control Mechanism (1)	Adversary in the Middle (1)	Account Discovery (1)	Exploitation of Remote Services (1)	Adversary in the Middle (1)	Application Layer Protocol (1)	Automated Exfiltration (1)	Account Access Removal (1)
Gather Victim Host Information (1)	Acquire Infrastructure (1)	Drive-by Compromise (1)	Command and Scripting Interference (1)	BITS Jobs (1)	Access Token Manipulation (1)	Brute Force (1)	Brute Force (1)	Application Window Discovery (1)	Archive Collected Data (1)	Archive Collected Data (1)	Communication Through Removable Media (1)	Data Transfer Size Limits (1)	Data Destruction (1)
Gather Victim Identity Information (1)	Compromise Accounts (1)	Exploit Public-Facing Application (1)	Container Administration Command (1)	Boot or Logon Autostart Execution (1)	Account Manipulation (1)	Browser Information Discovery (1)	Browser Information Discovery (1)	Browser Information Discovery (1)	Audio Capture (1)	Audio Capture (1)	Content Injection (1)	Exfiltration Over Alternative Protocol (1)	Data Encrypted for Impact (1)
Gather Victim Network Information (1)	Compromise Infrastructure (1)	External Remote Services (1)	Deploy Container (1)	Boot or Logon Initialization Scripts (1)	Boot or Logon Autostart Execution (1)	Cloud Infrastructure Discovery (1)	Exploitation for Credential Access (1)	Cloud Infrastructure Discovery (1)	Automated Collection (1)	Automated Collection (1)	Data Encoding (1)	Exfiltration Over C2 Channel (1)	Data Manipulation (1)
Gather Victim Org Information (1)	Develop Capabilities (1)	Hardware Additions (1)	Exploitation for Client Execution (1)	Browser Extensions (1)	Boot or Logon Initialization Scripts (1)	Cloud Service Dashboard (1)	Forced Authentication (1)	Cloud Service Dashboard (1)	Browser Session Hijacking (1)	Browser Session Hijacking (1)	Data Obfuscation (1)	Exfiltration Over Other Network Medium (1)	Defacement (1)
Phishing for Information (1)	Establish Accounts (1)	Phishing (1)	Inter-Process Communication (1)	Compromise Host Software Binary (1)	Boot or Logon Initialization Scripts (1)	Debugger Evasion (1)	Forge Web Credentials (1)	Cloud Service Discovery (1)	Remote Services (1)	Remote Services (1)	Dynamic Resolution (1)	Exfiltration Over Physical Medium (1)	Disk Wipe (1)
Search Cloud Sources (1)	Obtain Capabilities (1)	Replication Through Removable Media (1)	Native API (1)	Create or Modify System Binary (1)	Domain or Tenant Policy Modification (1)	Deobfuscate/Decode Files or Information (1)	Input Capture (1)	Cloud Storage Object Discovery (1)	Replication Through Removable Media (1)	Replication Through Removable Media (1)	Encrypted Channel (1)	Exfiltration Over Web Service (1)	Endpoint Denial of Service (1)
Search Open Technical Databases (1)	Shape Capabilities (1)	Supply Chain Compromise (1)	Scheduled Task/Job (1)	Create Account (1)	Domain or Tenant Policy Modification (1)	Deploy Container (1)	Multi Factor Authentication Interception (1)	Container and Resource Discovery (1)	Software Deployment Tools (1)	Software Deployment Tools (1)	Fallback Channels (1)	Financial Theft (1)	Firmware Corruption (1)
Search Victim-Owned Websites (1)		Trusted Relationship (1)	Shared Modules (1)	Event Triggered Execution (1)	Escape to Host (1)	Direct Volume Access (1)	Multi Factor Authentication Interception (1)	Debugger Evasion (1)	Taint Shared Content (1)	Taint Shared Content (1)	Hide Infrastructure (1)	Inhibit System Recovery (1)	Resource Hijacking (1)
		Valid Accounts (1)	Software Deployment Tools (1)	External Remote Services (1)	Event Triggered Execution (1)	Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Device Driver Discovery (1)	Use Alternate Authentication Material (1)	Use Alternate Authentication Material (1)	Ingress Tool Transfer (1)	Service Stop (1)	System Shutdown/Reboot (1)
			System Services (1)	Hijack Execution Flow (1)	Exploitation for Privilege Escalation (1)	Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	File and Directory Discovery (1)			Multi-Stage Channels (1)		
			User Execution (1)	Implant Internal Image (1)	Hijack Execution Flow (1)	Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Group Policy Discovery (1)			Non-Application Layer Protocol (1)		
			Windows Management Instrumentation (1)	Process Injection (1)	Process Injection (1)	Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Log Enumeration (1)			Protocol Tunneling (1)		
				Office Application Startup (1)	Scheduled Task/Job (1)	Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Network Service Discovery (1)			Screen Capture (1)		
				Power Settings (1)	Valid Accounts (1)	Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Network Share Discovery (1)			Video Capture (1)		
				Pre-OS Boot (1)		Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Password Policy Discovery (1)					
				Scheduled Task/Job (1)		Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Peripheral Device Discovery (1)					
				Server Software Component (1)		Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Permission Groups Discovery (1)					
				Traffic Signaling (1)		Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Process Discovery (1)					
				Valid Accounts (1)		Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Quarry Registry (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Remote System Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Software Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Information Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Location Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Network Configuration Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Network Connections Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Owner/User Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Service Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	System Time Discovery (1)					
						Domain or Tenant Policy Modification (1)	Multi Factor Authentication Interception (1)	Virtualization/Sandbox Evasion (1)					

MITRE ATT&CK - The TTP trio



Tactics, Techniques and Procedures

MITRE ATT&CK - The TTP trio



Tactics

Tactics represent the high-level **objectives** or **goals** that adversaries aim to achieve during a cyber attack. They describe the strategies employed by attackers to accomplish their mission.

Example:

- gaining initial access to a target network,
- establishing persistence,
- escalating privileges,
- exfiltrating data,
- disrupting operations.

Tactics serve as the primary categories for organizing and classifying adversary behavior.

MITRE ATT&CK - The TTP trio



Techniques

Techniques are the specific methods or procedures used by adversaries to achieve each **tactic**. They describe the step-by-step actions taken by attackers to accomplish their objectives.

Example:

Techniques under the "initial access" tactic may include:

- phishing emails,
- exploiting software vulnerabilities,
- leveraging stolen credentials to gain entry into a target network

MITRE ATT&CK - The TTP trio



Procedures (sub-techniques)

Variations or specific implementations of techniques that further refine the behaviors observed in cyber attacks.

They provide additional **granularity and detail** to techniques, allowing for more precise analysis and detection of adversary activity. Procedures describe specific ways in which techniques are executed or customized by attackers to suit their objectives or adapt to the target environment.

Example:

A procedure under the "exploitation of remote services" technique may involve exploiting a specific vulnerability in a web server software to gain unauthorized access.

APTs nature

Rely on subtle and slow operations and as such **traditional detection techniques** might fail.



What is needed?



APTs rely on subtle and slow operations.

This brings a lot of challenges for a detection technique because:

- Real time operation**
- Able to focus on context**
- Need to capture relation (cause-event) between (long-term) activities**
- Low false positive rate**
- Possibly detect attacks without prior knowledge**

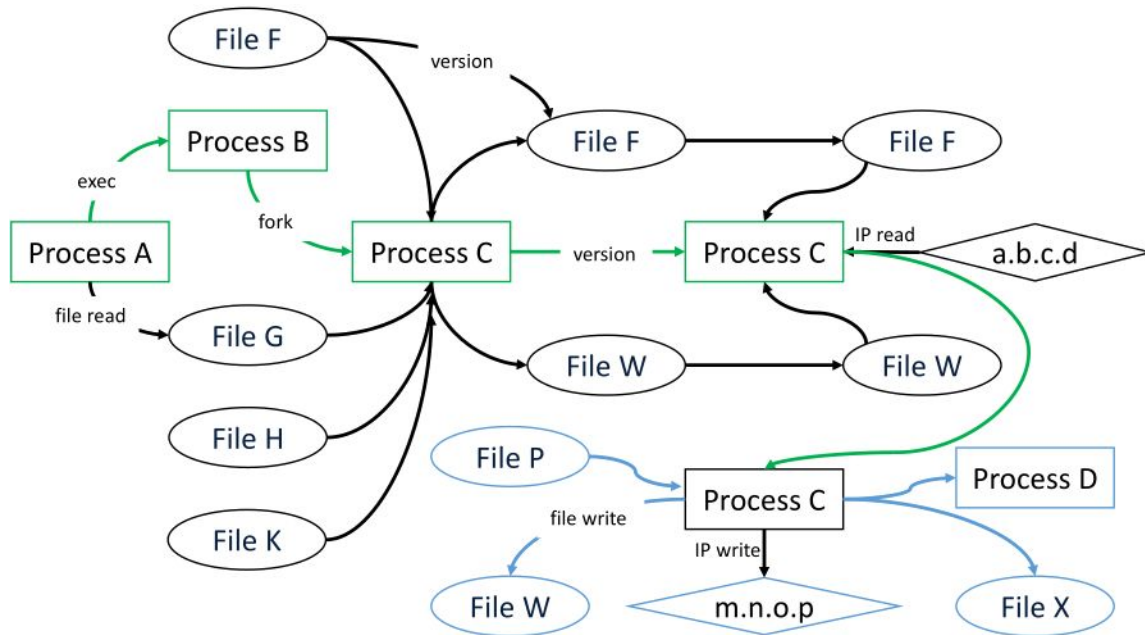
What is needed? Provenance

— — —



What is needed? Provenance

Provenance Graphs: Represent system execution as a Directed Acyclic Graph that describes information flow and causality (edges) between kernel objects (vertices, e.g., processes, files, sockets).

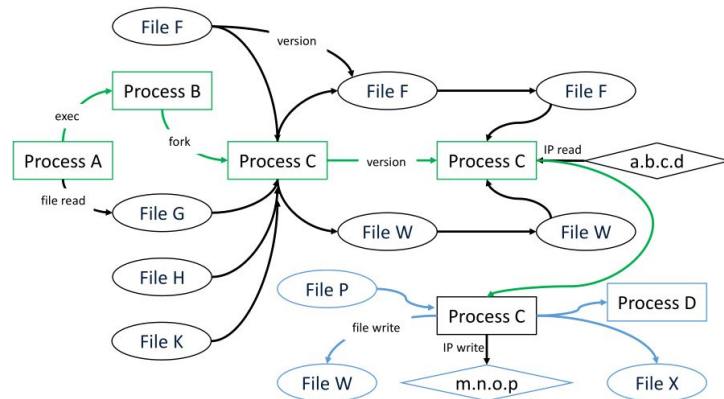


Provenance Graphs

Provenance Graphs: Represent system execution as a Directed Acyclic Graph that describes information flow and causality (edges) between kernel objects (vertices, e.g., processes, files, sockets).

Provenance Graphs:

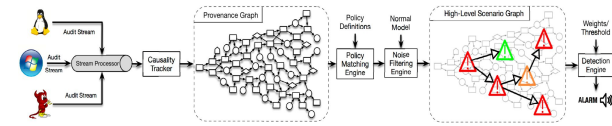
- Enable long term behaviour monitoring and eventually detection due to the connection of casually-related events in the data provenance graph.
- Provide information-rich context that can be used to better distinguish between benign/malicious events.



Steps

- **Alert generation**

- Map low-level events to generate semantically close alerts to the attackers behaviour (in our case to TTPs)



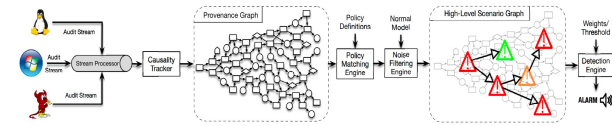
Steps

- **Alert generation**

- Map low-level events to generate semantically close alerts to the attackers behaviour (in our case to TTPs)

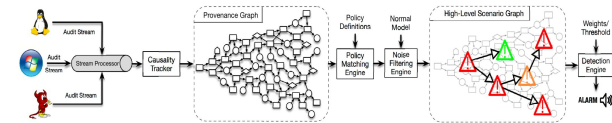
- **Alert Correlation**

- Take into account the flow of information between files/processes to generate a high-level scenario graph (HSG) where nodes correspond to TTPs and edges represent information flows between entities consisted in the TTPs



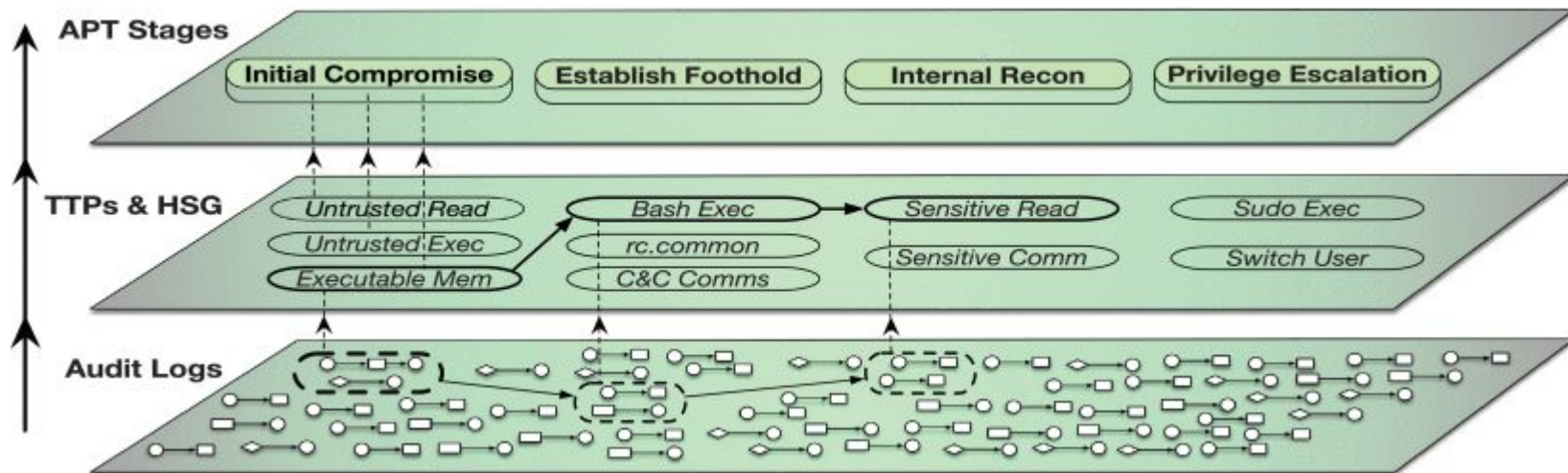
Steps

— — —



- **Alert generation**
 - Map low level events to generate semantically close alerts to the attackers behaviour (in our case to TTPs)
- **Alert Correlation**
 - Take into account the flow of information between files/processes to generate a high-level scenario graph (HSG) where nodes correspond to TTPs and edges represent information flows between entities consisted in the TTPs
- **Attack detection and HSG presentation**
 - Use the HSG to compute a “threat score” and raise an alarm if a predefined threshold is surpassed. The HSG is also presented to the cyber-analyst team for further processing.

Mapping the information



Utilize Mitre ATT&CK framework to map low-level system events to an intermediate high-level representation that can be then easily mapped to an APT campaigns' phases.

Reading Material

1. Advanced Persistent Threats: [Link-1](#), [Link-2](#)
2. Provenance based APT detection: [Link-1](#), [Link-2](#)